МІНІСТЕРСТВО ОСВІТИ І НАУКИ УКРАЇНИ

КИЇВСЬКИЙ НАЦІОНАЛЬНИЙ УНІВЕРСИТЕТ ІМЕНІ ТАРАСА ШЕВЧЕНКА

ФАКУЛЬТЕТ ІНФОРМАЦІЙНИХ ТЕХНОЛОГІЙ

КАФЕДРА ІНФОРМАЦІЙНИХ СИСТЕМ ТА ТЕХНОЛОГІЙ

Лабораторна робота № 3

з дисципліни **«Кібернетична безпека підприємства»**

Тема: «Аналіз кількісних та якісних методів ідентифікації активів: методики OCTAVE і FRAP для інформаційних активів власних пристроїв»

Виконав:

студент гр. ІР-31

Петро Кравченко

Перевірив:

Зараховано від

Борисенко Ірина Ігорівна

_____

(підпис викладача)

Київ-2026

ЗМІСТ

1. МЕТА ТА ЗАВДАННЯ РОБОТИ 3
2. КІЛЬКІСНІ ТА ЯКІСНІ МЕТОДИ ОЦІНКИ АКТИВІВ 4
2.1. Активи та їх класифікація 4
2.2. Кількісні методи 4
2.3. Якісні методи 5
3. МЕТОДИКА ОЦІНКИ РИЗИКІВ OCTAVE 6
3.1. Загальні положення та різновиди 6
3.2. OCTAVE Allegro 6
4. ГРУПОВИЙ ПРОЦЕС АНАЛІЗУ РИЗИКІВ FRAP 9
5. КЛАСИФІКАЦІЯ ІНФОРМАЦІЙНИХ АКТИВІВ ВЛАСНИХ ПРИСТРОЇВ 11
5.1. Контейнери та активи 11
5.2. Класифікація та оцінка активів 12
5.3. Кількісна оцінка очікуваних втрат 14
6. ОЦІНКА РИЗИКІВ КРИТИЧНОГО АКТИВУ ЗА OCTAVE ALLEGRO І FRAP 16
6.1. Кроки 1–3: критерії, профіль і контейнери 16
6.2. Кроки 4–8: сценарії загроз, бали та підхід 17
6.3. FRAP-сесія для пристроїв 19
7. ВІДПОВІДНІСТЬ «ІНФОРМАЦІЯ — ЗАГРОЗИ — МЕТОДИ І ЗАСОБИ УНИКНЕННЯ» 21
8. ВІДПОВІДІ НА ПИТАННЯ ДЛЯ САМОПЕРЕВІРКИ 23
ВИСНОВКИ 25
СПИСОК ВИКОРИСТАНИХ ДЖЕРЕЛ 26

1. МЕТА ТА ЗАВДАННЯ РОБОТИ

Мета роботи — ознайомитися з методикою оцінки ризиків OCTAVE та процесом аналізу ризиків FRAP [1]. Об’єктом практичної частини, як вимагає методичка, є інформаційні активи власних пристроїв автора: ноутбука, смартфона та пов’язаних з ними хмарних сервісів.

Завдання роботи відповідно до методичних рекомендацій [1]:

1) дослідити оцінку активів, яка проводиться кількісними та якісними методами (розділ 2);

2) проаналізувати методику оцінки ризиків OCTAVE (розділ 3);

3) проаналізувати груповий процес аналізу ризиків FRAP (розділ 4);

4) виконати класифікацію інформаційних активів, що знаходяться на власних пристроях (розділ 5);

5) сформулювати потенційні загрози інформації, визначити методи та засоби їх уникнення (розділи 6–7);

6) заповнити таблицю відповідності «інформація — загрози — методи і засоби уникнення» (розділ 7).

Відповіді на питання для самоперевірки наведено в розділі 8, аналіз результатів — у висновках. Грошові оцінки активів є власними орієнтовними оцінками автора станом на жовтень 2026 року.

2. КІЛЬКІСНІ ТА ЯКІСНІ МЕТОДИ ОЦІНКИ АКТИВІВ

2.1. Активи та їх класифікація

Аналіз ризиків інформаційної безпеки передбачає облік активів і встановлення їхньої цінності, класифікацію загроз і вразливостей, визначення ймовірності та впливу загроз і оптимізацію витрат між збитками та вартістю захисту [1]. Активи бувають матеріальними (мережеве обладнання, комп'ютери, програмне забезпечення, устаткування, матеріали) і нематеріальними (репутація, інформація, авторське право); кількісно оцінити нематеріальні активи значно важче [1]. Об'єктами кібербезпеки є інформаційні, програмні, апаратні, мережеві ресурси та бізнес-процеси [2].

Під час визначення цінності враховують корисність активу для власника, його цінність для конкурентів і користувачів, витрати на купівлю, розроблення, захист, заміну чи ремонт і наслідки компрометації; саме цінність активів визначає механізми та заходи їх захисту [1]. На підприємстві оцінку виконує група управління інформаційними ризиками з керівників підрозділів, IT-працівників і розробників застосунків, а керівництво за її звітом визначає обсяг проєкту [1].

2.2. Кількісні методи

Кількісні методи виражають цінність і ризик у грошових одиницях. Фактична вартість активу визначається вартістю його придбання, розроблення та підтримки [1]. Для розрахунку очікуваних втрат застосовують класичні показники кількісного аналізу ризиків:

– AV (asset value) — вартість активу;

– EF (exposure factor) — частка вартості, що втрачається за однієї реалізації загрози (0…1);

– SLE = AV × EF — очікувані втрати від одного інциденту;

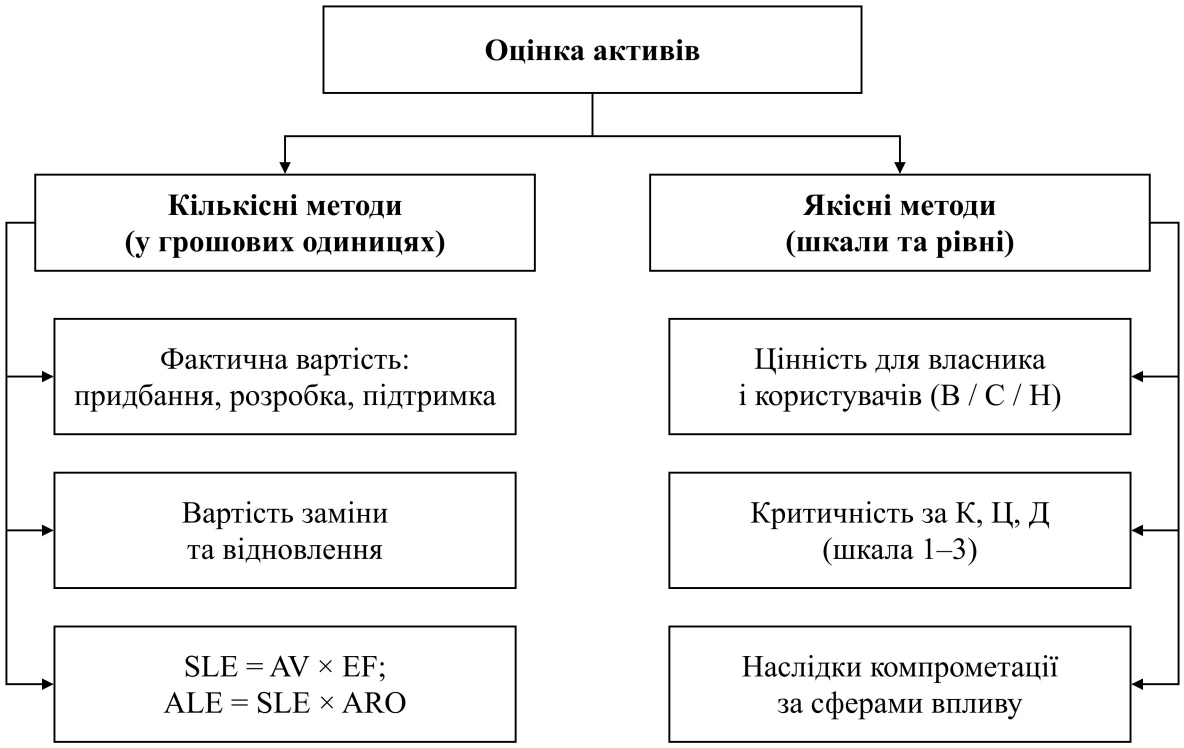
– ARO — очікувана кількість інцидентів за рік;

– ALE = SLE × ARO — очікувані річні втрати, з якими порівнюють річну вартість заходу захисту.

Захід економічно виправданий, якщо його річна вартість менша за зменшення ALE, яке він забезпечує. Недолік кількісних методів — потреба в статистиці інцидентів, якої для більшості організацій немає.

2.3. Якісні методи

Якісні методи описують цінність і ризик порядковими шкалами (високий / середній / низький, 1–3, 1–10), отриманими з експертних оцінок власників і користувачів активу [1]. Вони швидші й не потребують статистики, але суб’єктивні. Якісні шкали використовують OCTAVE і FRAP, а CRAMM поєднує обидва підходи [1; 3]. Класифікацію методів подано на рис. 3.1.



Комбіновані методики (CRAMM) поєднують обидва підходи

Рис. 3.1 — Кількісні та якісні методи оцінки активів

3. МЕТОДИКА ОЦІНКИ РИЗИКІВ OCTAVE

3.1. Загальні положення та різновиди

Методику OCTAVE (Operationally Critical Threat, Asset, and Vulnerability Evaluation) розробив Software Engineering Institute (SEI) Університету Карнегі — Меллона. Вона передбачає аналіз ризиків силами працівників підприємства без залучення зовнішніх консультантів, оскільки вони краще розуміють потреби підприємства й властиві йому ризики; основними перевагами є загальнодоступність і безкоштовність [1]. Базовий підхід викладено розробниками в монографії [4].

Існує три різновиди [5; 6]:

– OCTAVE — три фази: побудова профілів загроз на основі активів, ідентифікація вразливостей інфраструктури, розроблення стратегії безпеки та планів зменшення ризиків;

– OCTAVE-S — варіант для малих організацій (близько 100 осіб і менше), який виконує команда з трьох — п’яти працівників без формальних семінарів збирання знань;

– OCTAVE Allegro (2007) — спрощений підхід, зосереджений на інформаційних активах і місцях їх зберігання, передавання й обробки (контейнерах); придатний і для групи, і для однієї особи.

3.2. OCTAVE Allegro

OCTAVE Allegro складається з восьми кроків, згрупованих у чотири фази (рис. 3.2) [5]. У фазі 1 встановлюють критерії вимірювання ризику, у фазі 2 профілюють критичні активи й визначають їхні контейнери, у фазі 3 ідентифікують загрози в контексті контейнерів, у фазі 4 ідентифікують і аналізують ризики та обирають підхід до їх зменшення.

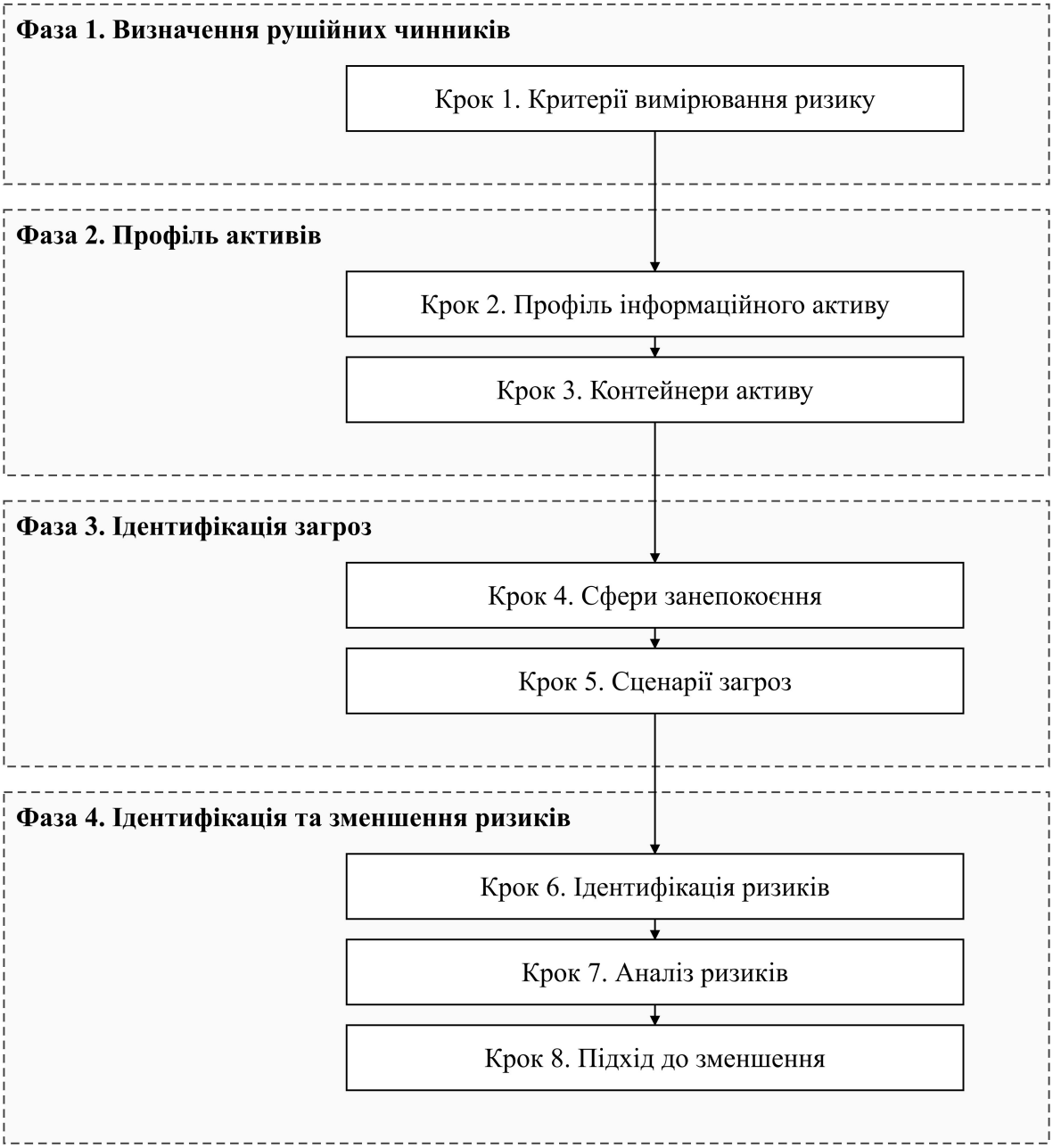


Рис. 3.2 — Фази та кроки методики OCTAVE Allegro

Загрози систематизують деревами загроз з чотирма гілками: люди з використанням технічних засобів, люди з фізичним доступом, технічні проблеми та інші проблеми (стихійні лиха, відмови інфраструктури). Ймовірність описують якісно — висока, середня або низька. На кроці 7 обчислюють відносний бал ризику: для кожної сфери впливу ранг сфери (найважливіша — найбільший ранг) множать на значення впливу (високий — 3, середній — 2, низький — 1) і підсумовують [5]. Методичка зазначає, що для

кожного джерела загроз будується дерево варіантів, а ризик оцінюється за трьома рівнями з можливим фінансовим збитком [1].

На кроці 8 ризики розподіляють на пули за матрицею «ймовірність × бал» (30–45, 16–29, 0–15) і призначають підхід: пул 1 — зменшити, пул 2 — зменшити або відкласти, пул 3 — відкласти або прийняти, пул 4 — прийняти; передавання ризику допустиме для будь-якого пулу [5]. Різниця балів значення не має — бал лише впорядковує ризики.

4. ГРУПОВИЙ ПРОЦЕС АНАЛІЗУ РИЗИКІВ FRAP

FRAP (Facilitated Risk Analysis Process) — методика якісної оцінки ризиків, побудована так, що будь-яка людина з навичками організації групової роботи може провести аналіз [1]. Її описав Т. Пелтьє; процес складається з попередньої зустрічі, сесії FRAP і підсумкового етапу (рис. 3.3) [7]. Група з власників процесів і технічних фахівців аналізує одну систему чи один сегмент діяльності за раз, а фасилітатор стежить за регламентом.

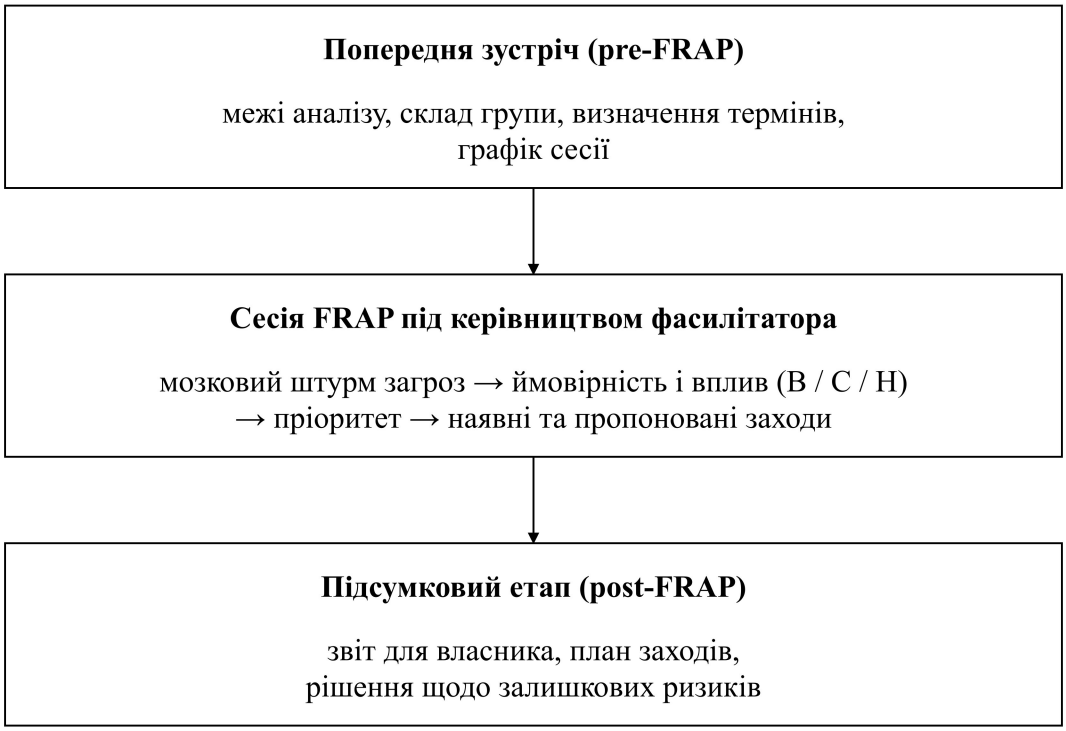


Рис. 3.3 — Етапи групового процесу аналізу ризиків FRAP

Етапи сесії за методичкою [1]: мозковий штурм для встановлення всіх загроз; визначення ймовірності та вразливостей для кожної загрози за шкалою велика / середня / низька; формування звіту щодо можливого впливу кожної загрози. Перевага — швидкість і простота прийняття рішень; недолік — суб’єктивність і лише якісний результат. Методичка рекомендує OCTAVE для невеликих підприємств, FRAP — для середніх, CRAMM — для великих [1].

Порівняння двох методик з CRAMM наведено в табл. 3.1.

Таблиця 3.1 — Порівняння методик OCTAVE, FRAP і CRAMM

Ознака	OCTAVE (Allegro)	FRAP	CRAMM
Виконавці	працівники організації або одна особа	група з фасилітатором	навчений аналітик зі спеціальним засобом
Тип оцінки	якісна з відносним балом	якісна (В / С / Н)	комбінована (1–10, 1–7)
Центр уваги	інформаційні активи та контейнери	загрози окремої системи	активи, загрози, вразливості, контрзаходи
Тривалість	кілька днів	одна сесія + звіт	тижні
Вартість	безкоштовна	безкоштовна	платна ліцензія
Масштаб за методичкою	невеликі підприємства	середні	великі

5. КЛАСИФІКАЦІЯ ІНФОРМАЦІЙНИХ АКТИВІВ ВЛАСНИХ ПРИСТРОЇВ

5.1. Контейнери та активи

Ідентифікацію активів виконано за підходом OCTAVE Allegro: спершу визначено контейнери — місця, де активи зберігаються, передаються та обробляються (табл. 3.2), потім розміщені в них активи (рис. 3.4).

Таблиця 3.2 — Контейнери інформаційних активів

Код	Контейнер	Тип	Вартість, грн
Н	Ноутбук (ОС Linux, шифрування диска)	технічний	38 000
С	Смартфон (ОС Android)	технічний	18 000
Х	Хмарні сервіси (пошта, GitHub, хмарне сховище, менеджер паролів)	технічний (зовнішній)	—
Д	Зовнішній диск резервних копій	технічний	2 500
Р	Домашній маршрутизатор Wi-Fi	технічний	2 000
К	Кімната гуртожитку / квартира	фізичний	—
В	Власник (я) і члени родини	людський	—

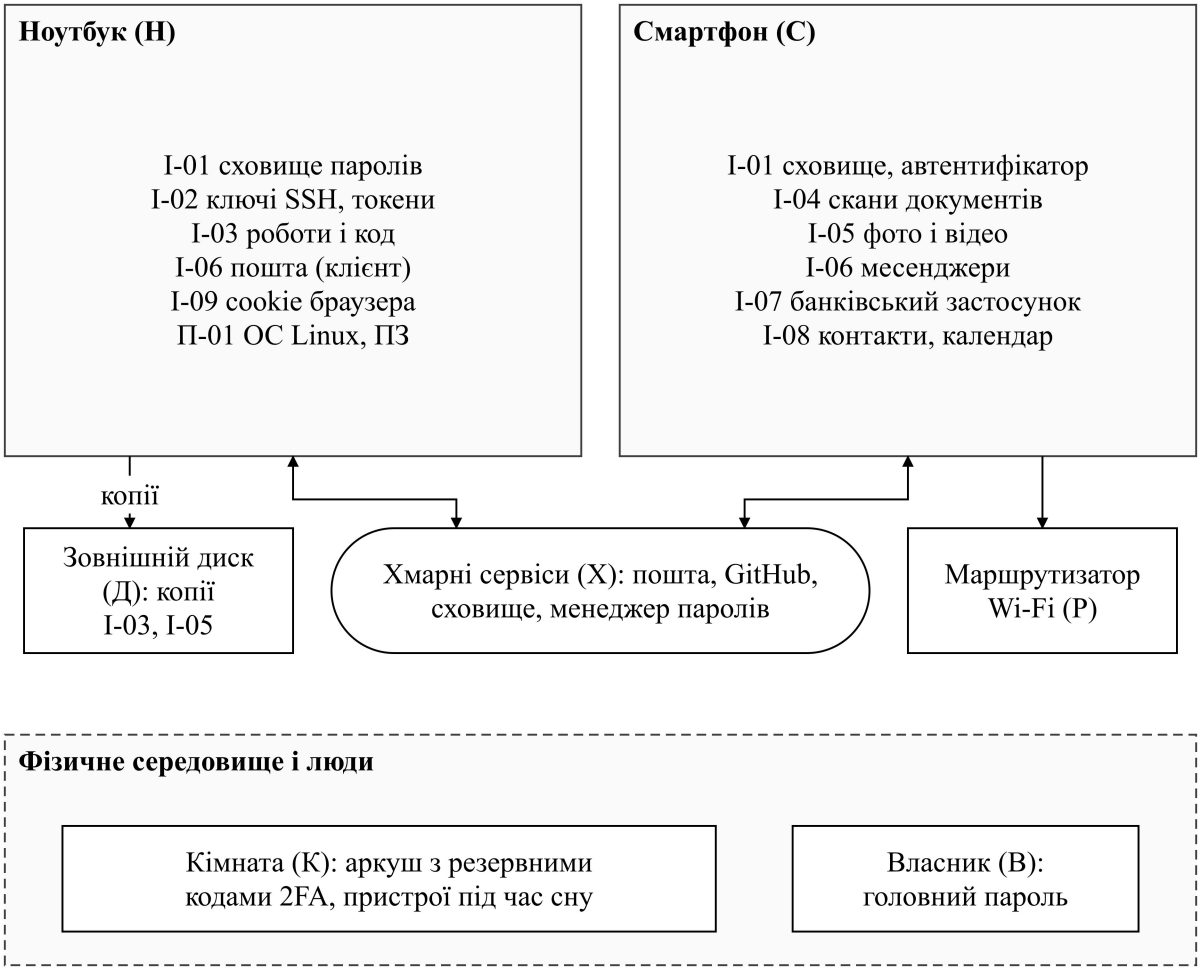


Рис. 3.4 — Карта інформаційних активів за контейнерами

Двосторонні стрілки на рис. 3.4 позначають синхронізацію з хмарними сервісами; отже, ризики хмари успадковують усі активи, що синхронізуються, а ризики пристрою — усі активи на ньому.

5.2. Класифікація та оцінка активів

Класифікацію (табл. 3.3) виконано за видом активу, позначеним першою літерою коду (І — інформаційний, П — програмний, А — апаратний), категорією доступу (критична, конфіденційна, особиста, відкрита) і критичністю за конфіденційністю, цілісністю та доступністю (1 — низька, 3 — висока). Цінність оцінено кількісно в гривнях і переведено в якісний рівень: висока — від 25 000 грн, середня — від 8 000 грн, низька — менше 8 000 грн.

Таблиця 3.3 — Класифікація інформаційних активів власних пристроїв

Код	Актив	Конт.	Категорія	К	Ц	Д	Цінність, грн	Рівень
І-01	Паролі, сховище менеджера паролів, резервні коди 2FA	Н, С, Х	критична	3	3	3	60 000	висока
І-02	Ключі SSH і токени доступу до GitHub	Н, Х	конфіденційна	3	3	2	15 000	середня
І-03	Навчальні роботи, вихідний код, звіти	Н, Х, Д	особиста (внутрішня)	1	3	3	40 000	висока
І-04	Скани паспорта, ІПН, диплома, договорів	С, Х	конфіденційна (ПД)	3	2	2	30 000	висока
І-05	Особисті фото та відео	С, Х, Д	особиста	2	1	2	20 000	середня
І-06	Листування: пошта й месенджери	С, Н, Х	конфіденційна	3	2	2	15 000	середня
І-07	Банківський застосунок і платіжні картки	С	критична	3	3	3	25 000	висока
І-08	Контакти, календар, розклад	С, Х	особиста	2	2	2	3 000	низька

Продовження таблиці 3.3

Код	Актив	Конт.	Категорія	К	Ц	Д	Цінність, грн	Рівень
І-09	Cookie сесій і історія браузера	Н, С	конфіденційна	3	1	1	8 000	середня
П-01	Операційні системи та прикладне ПЗ	Н, С	відкрита	1	3	3	4 000	низька
А-01	Ноутбук	К	—	1	2	3	38 000	висока
А-02	Смартфон	К, В	—	1	2	3	18 000	середня
А-03	Зовнішній диск резервних копій	К	—	1	2	2	2 500	низька
А-04	Домашній маршрутизатор	К	—	1	2	3	2 000	низька

Із 14 активів високу цінність мають 5, середню — 5, низьку — 4. Сумарна цінність інформаційних активів (216 000 грн) перевищує вартість обладнання (60 500 грн) — це кількісно підтверджує тезу, що головна цінність пристрою — дані, а не «залізо». Найціннішим є І-01 (паролі та коди 2FA): його компрометація відкриває доступ до більшості інших активів, тому його обрано критичним активом для OCTAVE Allegro.

5.3. Кількісна оцінка очікуваних втрат

Для шести найімовірніших загроз розраховано SLE і ALE (табл. 3.4). Значення EF і ARO оцінено експертно: наприклад, ARO = 0,3 для смартфона означає одну втрату приблизно за три роки.

Таблиця 3.4 — Кількісна оцінка очікуваних втрат (SLE, ALE)

Актив	Загроза	AV, грн	EF	SLE, грн	ARO	ALE, грн/рік
А-02	Крадіжка або втрата смартфона	18 000	1,0	18 000	0,3	5 400
І-07	Шахрайство з карткою після дзвінка «зі служби банку»	25 000	0,4	10 000	0,2	2 000
І-03	Відмова SSD ноутбука без актуальної копії	40 000	0,5	20 000	0,1	2 000
І-01	Компрометація головного пароля менеджера паролів	60 000	0,8	48 000	0,05	2 400
І-04	Витік сканів документів із хмари	30 000	0,5	15 000	0,1	1 500
А-01	Пошкодження ноутбука (рідина, падіння)	38 000	0,6	22 800	0,15	3 420

Сумарні очікувані річні втрати становлять 16 720 грн. Найбільший ALE має крадіжка або втрата смартфона (5 400 грн/рік): хоча шкода від компрометації паролів (48 000 грн) найбільша, вона рідкісна. Отже, кількісний підхід виправдовує витрати на чохол, страхування та функцію віддаленого стирання телефона, а якісний (OCTAVE) — пріоритет захисту паролів; методики доповнюють одна одну.

6. ОЦІНКА РИЗИКІВ КРИТИЧНОГО АКТИВУ ЗА OCTAVE ALLEGRO І FRAP

6.1. Кроки 1–3: критерії, профіль і контейнери

Крок 1. Критерії вимірювання ризику встановлено для п’яти сфер впливу; ранг 5 має найважливіша сфера (табл. 3.5).

Таблиця 3.5 — Сфери впливу та критерії вимірювання ризику (крок 1)

Сфера впливу	Ранг	Критерії: високий / середній / низький вплив
Фінанси	5	прямі втрати коштів: високий — понад 10 000 грн; середній — 1 000–10 000; низький — до 1 000
Навчання і продуктивність	4	високий — зрив здачі робіт; середній — затримка до тижня; низький — години
Приватність і репутація	3	високий — публічне розголошення; середній — коло знайомих; низький — без наслідків
Юридичні наслідки	2	високий — кредит чи договір на моє ім’я; середній — звернення до поліції; низький — немає
Здоров’я і безпека	1	високий — загроза фізичній безпеці; середній — стрес; низький — немає

Кроки 2–3. Профіль критичного активу та його контейнери наведено в табл. 3.6.

Таблиця 3.6 — Профіль критичного активу і контейнери (кроки 2–3)

Елемент профілю	Зміст
Критичний актив	І-01 Паролі, сховище менеджера паролів, резервні коди 2FA
Обґрунтування вибору	компрометація відкриває доступ до І-02, І-04, І-06, І-07 одночасно
Власник	я (студент); родина не має доступу
Вимоги безпеки	К — лише власник; Ц — зміни лише власником; Д — доступ з будь-якого пристрою за хвилини
Найважливіша властивість	конфіденційність
Контейнер (технічний внутрішній)	ноутбук: застосунок менеджера паролів, браузер
Контейнер (технічний внутрішній)	смартфон: застосунок менеджера паролів, застосунок-автентифікатор
Контейнер (технічний зовнішній)	хмарна синхронізація зашифрованого сховища
Контейнер (фізичний)	паперовий аркуш з резервними кодами 2FA у шухляді
Контейнер (людський)	пам’ять власника: головний пароль

6.2. Кроки 4–8: сценарії загроз, бали та підхід

Сфери занепокоєння розгорнуто в сценарії загроз за чотирма деревами загроз OCTAVE (рис. 3.5). Кожен сценарій описує актора, засіб, мотив і наслідок.

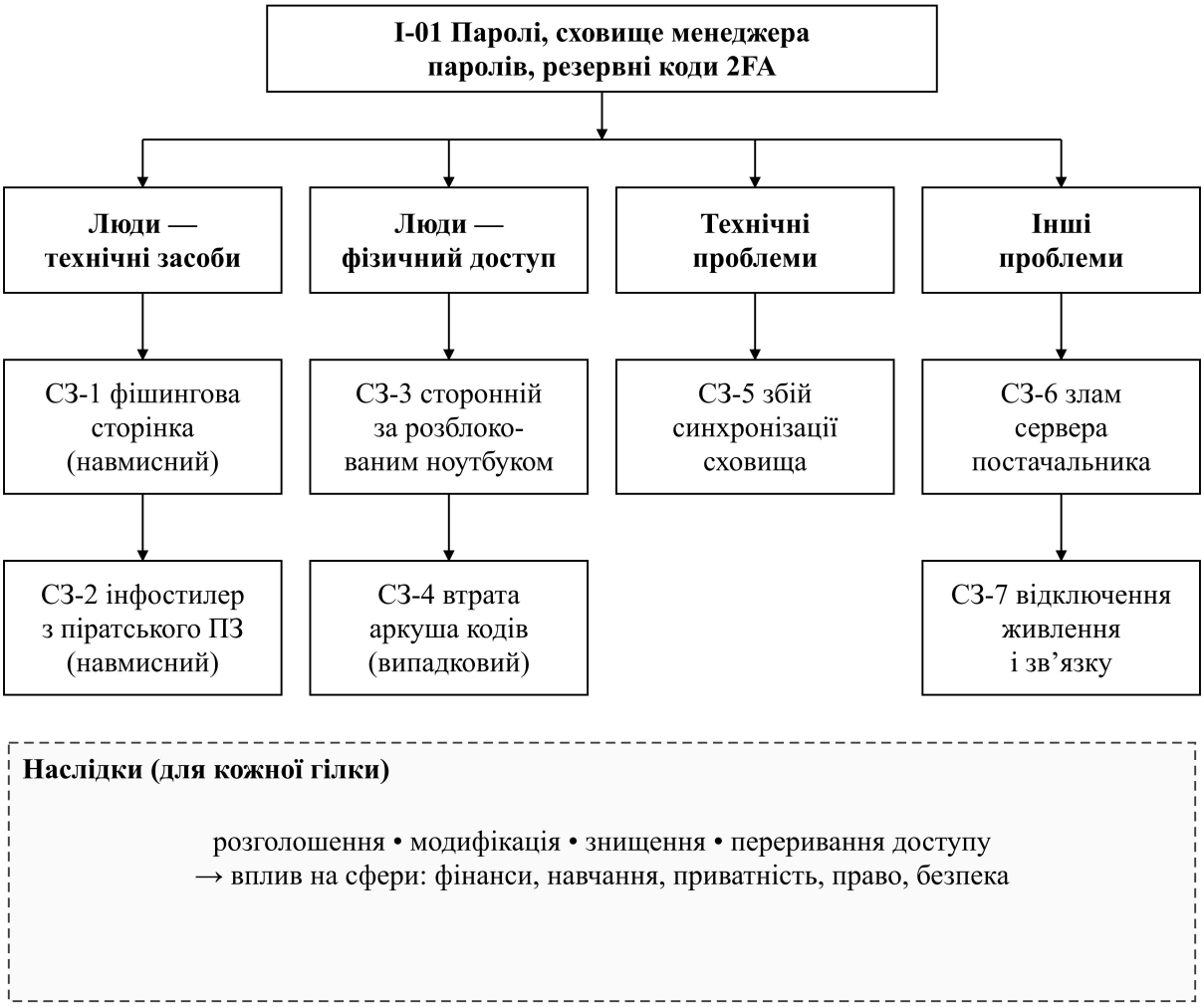


Рис. 3.5 — Дерева загроз OCTAVE для критичного активу I-01

Для кожного сценарію визначено значення впливу в кожній сфері, ймовірність, відносний бал і пул (табл. 3.7). Значення впливу за сферами (Ф — фінанси, Н — навчання, П — приватність, Ю — юридичні наслідки, З — здоров’я) позначено В / С / Н; Р — ймовірність.

Таблиця 3.7 — Аналіз ризиків критичного активу за OCTAVE Allegro (кроки 4–8)

Код	Засіб і мотив	Наслідок	Ф Н П Ю З	Р	Бал	Пул	Підхід
СЗ-1	фішингова сторінка входу (навмисний)	розголошення	В С В С Н	В	37	1	зменшити
СЗ-2	піратський застосунок / розширення (навмисний)	розголошення	В В В С Н	С	41	2	зменшити або відкласти
СЗ-3	розблокований ноутбук (навмисний)	розголошення, модифікація	С С С Н Н	Н	27	3	відкласти або прийняти
СЗ-4	втрата аркуша з резервними кодами (випадковий)	знищення (втрата доступу)	Н В Н Н Н	С	23	2	зменшити або відкласти
СЗ-5	збій синхронізації або пошкодження сховища (випадковий)	знищення, переривання	Н С Н Н Н	Н	19	3	відкласти або прийняти
СЗ-6	компрометація сервера постачальника хмарного сховища (навмисний)	розголошення (зашифрованих даних)	С Н С Н Н	Н	23	3	відкласти або прийняти
СЗ-7	відключення електроенергії та зв’язку (випадковий)	переривання	Н С Н Н Н	В	19	2	зменшити або відкласти

Приклад розрахунку для СЗ-1: $5\cdot3 + 4\cdot2 + 3\cdot3 + 2\cdot2 + 1\cdot1 = 37$; ймовірність висока, бал у діапазоні 30–45 → пул 1 «зменшити».

Розподіл за пулами: пул 1 — 1; пул 2 — 3; пул 3 — 3. Заходи зменшення для сценаріїв пулів 1 і 2 та відкладені заходи для пулу 3 наведено в табл. 3.8.

Таблиця 3.8 — Стратегія зменшення ризиків критичного активу (крок 8)

Код	Пул	Захід
СЗ-1	1	апаратний ключ FIDO2 / passkey, автозаповнення лише на справжньому домені
СЗ-2	2	ПЗ лише з офіційних репозиторіїв, мінімум розширень браузера, оновлення
СЗ-4	2	друга копія кодів у запечатаному конверті в батьків
СЗ-7	2	офлайн-доступ до кешованого сховища, повербанк
СЗ-3	3	автоблокування за 2 хв, блокування сховища при бездіяльності
СЗ-6	3	довгий головний пароль, наскрізне шифрування сховища
СЗ-5	3	щомісячний експорт зашифрованого сховища на зовнішній диск

6.3. FRAP-сесія для пристроїв

Для всіх пристроїв проведено скорочену FRAP-сесію тривалістю близько години. Склад групи:

– фасилітатор — однокурсник, який веде сесію і стежить за регламентом

– власник активів (я) — опис активів і наявних заходів

– член родини, що користується домашньою мережею, — погляд користувача

– секретар (запис рішень) — роль виконує фасилітатор

Під час мозкового штурму сформульовано загрози, для кожної визначено ймовірність і вплив за шкалою В / С / Н [1]. Пріоритет визначено за прийнятою в роботі матрицею 3 × 3: пріоритет 1 — якщо хоча б один показник високий, а інший не нижчий за середній; пріоритет 3 — якщо обидва не вищі за середній і хоча б один низький; решта — пріоритет 2 (табл. 3.9).

Таблиця 3.9 — Результати FRAP-сесії для власних пристроїв

Код	Загроза	Вразливість	Ймов.	Вплив	Наявний захід	Пріоритет
Ф-01	Фішинг облікових даних пошти	однаковий шаблон листів, поспіх	В	В	2FA через SMS	1 — негайні заходи
Ф-02	Крадіжка смартфона в транспорті	носіння в кишені куртки	С	В	PIN, шифрування	1 — негайні заходи
Ф-03	Інфостилер з піратського ПЗ	встановлення ПЗ з неофіційних сайтів	Н	В	немає	2 — планові заходи
Ф-04	Відмова SSD ноутбука	копії робляться нерегулярно	С	В	Git-репозиторій у хмарі	1 — негайні заходи
Ф-05	Злам домашнього маршрутизатора	заводський пароль адміністратора	С	С	WPA2	2 — планові заходи
Ф-06	Перегляд даних стороннім у гуртожитку	ноутбук без автоблокування	С	С	пароль входу	2 — планові заходи
Ф-07	Шахрайський дзвінок «зі служби банку»	довіра до дзвінків	С	В	ліміти картки	1 — негайні заходи
Ф-08	Витік сканів документів із месенджера	надсилання сканів у чати	С	С	немає	2 — планові заходи
Ф-09	Втрата доступу через втрату резервних кодів	єдина паперова копія	Н	С	немає	3 — прийняти, стежити
Ф-10	Публікація приватних фото після злому хмари	слабкий пароль хмари	Н	С	немає	3 — прийняти, стежити

Пріоритет 1 мають 4 загрози (Ф-01, Ф-02, Ф-04, Ф-07), пріоритет 2 — 4, пріоритет 3 — 2. Результати FRAP збігаються з OCTAVE: найвищий пріоритет — фішинг (Ф-01 ≈ СЗ-1) і втрата пристрою; FRAP охопив ширше коло активів, а OCTAVE дав детальніший аналіз одного критичного активу.

7. ВІДПОВІДНІСТЬ «ІНФОРМАЦІЯ — ЗАГРОЗИ — МЕТОДИ І ЗАСОБИ УНИКНЕННЯ»

За завданнями 5–6 для кожної групи активів сформульовано потенційні загрози, методи (організаційні та технічні) і конкретні засоби їх уникнення (табл. 3.10). Заходи узгоджено з лекцією про кіберзагрози: фішинг, шкідливе ПЗ, програми-вимагачі та фізичні вектори атак через носії [8].

Таблиця 3.10 — Відповідність «інформація — загрози — методи і засоби уникнення»

Інформація (актив)	Загрози	Методи уникнення	Засоби
І-01 Паролі, менеджер паролів, коди 2FA	фішинг; інфостилер; підглядання; втрата кодів	організаційні: унікальні паролі, перевірка домену; технічні: менеджер паролів з шифруванням, FIDO2-ключ	KeePassXC / Bitwarden, апаратний ключ FIDO2
І-02 Ключі SSH і токени GitHub	крадіжка файлу ключа; витік токена в коді	ключ з парольною фразою, токени з мінімальними правами й строком дії, сканування секретів	ssh-agent, ключі ed25519, GitHub secret scanning
І-03 Навчальні роботи і код	відмова диска; програма-вимагач; випадкове видалення	правило резервування 3-2-1: дві локальні копії й одна поза домом, версіонування	Git + GitHub, зовнішній диск, rsync / Borg
І-04 Скани документів	витік із месенджера чи хмари; шахрайство від мого імені	мінімізація: не пересилати скани в чати, водяний знак «копія для …», шифрування архіву	зашифрований контейнер (VeraCrypt), «Дія» замість сканів
І-05 Особисті фото і відео	злам хмари; втрата телефона	надійний пароль і 2FA хмари, резервна копія на зовнішньому диску	хмарне сховище з 2FA, зовнішній диск
І-06 Листування	злам облікового запису; соціальна інженерія	2FA через застосунок-автентифікатор, перевірка нових сеансів, обережність із посиланнями	автентифікатор TOTP, вбудовані налаштування безпеки месенджерів

Продовження таблиці 3.10

Інформація (актив)	Загрози	Методи уникнення	Засоби
І-07 Банківський застосунок	вішинг; крадіжка телефона; шкідливі застосунки	ніколи не повідомляти коди, ліміти й віртуальна картка для інтернету, біометрія	налаштування лімітів банку, Google Play Protect
І-08 Контакти, календар	втрата телефона; надмірні дозволи застосунків	синхронізація з хмарою, перегляд дозволів	керування дозволами Android
І-09 Cookie і історія браузера	перехоплення сесії інфостилером; спільний комп’ютер	вихід із сеансів, очищення cookie, окремий профіль браузера	налаштування браузера, мінімум розширень
П-01 ОС і ПЗ	експлуатація вразливостей; шкідливе ПЗ	своєчасні оновлення, ПЗ лише з офіційних джерел, міжмережевий екран	менеджер пакетів ОС, ufw / firewalld, Google Play
А-01, А-02 Ноутбук і смартфон	крадіжка; втрата; фізичний доступ сторонніх	повне шифрування диска, автоблокування, віддалений пошук і стирання	LUKS, шифрування Android, «Знайти пристрій»
А-04 Маршрутизатор	злам через заводський пароль; застаріла прошивка	зміна пароля адміністратора, WPA3 / WPA2-AES, вимкнення WPS, оновлення прошивки	вебінтерфейс маршрутизатора

Три заходи перекривають більшість загроз: менеджер паролів з апаратним ключем FIDO2 (І-01, І-06, І-07, І-09), повне шифрування пристроїв з автоблокуванням (А-01, А-02 і всі дані на них) і резервування за правилом 3-2-1 (І-03, І-05). Їх упроваджено першими.

8. ВІДПОВІДІ НА ПИТАННЯ ДЛЯ САМОПЕРЕВІРКИ

Питання 1. Дайте визначення «нематеріальні активи підприємства», що відноситься до цієї категорії?

Відповідь. Нематеріальні активи — ресурси без фізичної форми, що мають цінність для підприємства: інформація (бази даних, документи, ноу-хау), репутація, авторське право й інша інтелектуальна власність, програмні ліцензії. Їх важче оцінити кількісно, ніж матеріальні.

Питання 2. Дайте визначення активів підприємства. Наведіть приклади.

Відповідь. Актив — будь-який ресурс, що має цінність для підприємства і тому потребує захисту: інформація, програмне забезпечення, обладнання, мережі, персонал, процеси. Приклади з роботи — сховище паролів, вихідний код, ноутбук, маршрутизатор (табл. 3.3).

Питання 3. Що таке активи підприємства? Які їх джерела та класифікація?

Відповідь. Джерела активів — придбання (обладнання, ліцензії), власне створення (дані, код, документи) та отримання від партнерів і клієнтів (персональні дані). Класифікують за видом (інформаційні, програмні, апаратні, мережеві, людські, процеси), формою (матеріальні та нематеріальні), категорією доступу й критичністю за К, Ц, Д.

Питання 4. Які особливості методики оцінки ризиків OCTAVE?

Відповідь. Самостійне виконання працівниками без зовнішніх консультантів, фокус на критичних інформаційних активах і контейнерах, дерева загроз, якісні шкали з відносним балом, безкоштовність; різновиди — OCTAVE, OCTAVE-S, OCTAVE Allegro (розділ 3).

Питання 5. Які особливості групового процесу аналізу ризиків FRAP?

Відповідь. Якісний аналіз однієї системи групою під керівництвом фасилітатора: мозковий штурм загроз, оцінка ймовірності й впливу за шкалою В / С / Н, пріоритизація і звіт. Швидкий і простий, але суб’єктивний (розділ 4, табл. 3.9).

Питання 6. Якими методами проводиться оцінка активів підприємства?

Відповідь. Кількісними (фактична вартість, вартість заміни, SLE, ALE) і якісними (рівні цінності, критичність за К, Ц, Д, наслідки за сферами впливу); комбіновані методики, як-от CRAMM, поєднують обидва підходи (рис. 3.1).

Питання 7. Розкрийте поняття «матеріальні активи підприємства», що відноситься до цієї категорії?

Відповідь. Матеріальні активи мають фізичну форму і ринкову вартість: комп’ютери, сервери, мережеве обладнання, носії, устаткування, матеріали; методичка відносить сюди й програмне забезпечення. Їх оцінюють за вартістю придбання, підтримки та заміни (А-01…А-04 у табл. 3.3).

ВИСНОВКИ

У лабораторній роботі досліджено кількісні та якісні методи оцінки активів і застосовано методики OCTAVE Allegro та FRAP до інформаційних активів власних пристроїв.

1) Розглянуто кількісні (AV, SLE, ALE) і якісні (рівні, К/Ц/Д, сфери впливу) методи оцінки активів, їхні переваги та обмеження.

2) Проаналізовано OCTAVE та її різновиди, зокрема вісім кроків OCTAVE Allegro з відносним балом і пулами, і груповий процес FRAP; порівняно їх з CRAMM.

3) Класифіковано 14 активів у 7 контейнерах; високу цінність мають 5; інформаційні активи цінніші за обладнання.

4) Розраховано очікувані річні втрати для 6 загроз (разом 16 720 грн/рік).

5) За OCTAVE Allegro проаналізовано 7 сценаріїв загроз для критичного активу I-01; за FRAP — 10 загроз для всіх пристроїв; результати узгоджуються.

6) Заповнено таблицю «інформація — загрози — методи і засоби уникнення» (12 рядків).

Аналіз результатів показує, що кількісні методи добре обґрунтовують витрати на захист обладнання, а якісні — пріоритети для нематеріальних активів, грошова оцінка яких умовна. Для особистих пристроїв, як і для невеликого підприємства, OCTAVE Allegro придатна для самостійного виконання однією особою, а FRAP дає швидкий загальний огляд. Найбільший ризик пов’язаний з людським чинником — фішингом, тому головний захід — автентифікація, стійка до фішингу.

СПИСОК ВИКОРИСТАНИХ ДЖЕРЕЛ

1. Борисенко І. І., Гладка М. В. Кібернетична безпека підприємства : рекомендації до виконання лабораторних робіт для здобувачів освітнього ступеня «бакалавр» спеціальності 126 «Інформаційні системи та технології». Київ : КНУ імені Тараса Шевченка, 2025. 33 с.

2. Кібернетична безпека підприємства: поняття, принципи та сучасні виклики : лекція 1 з дисципліни «Кібернетична безпека підприємства». Київ : КНУ імені Тараса Шевченка, 2026.

3. Yazar Z. A qualitative risk analysis and management tool — CRAMM : GSEC practical assignment. SANS Institute, 2002. URL: https://www.giac.org/paper/gsec/1746/qualitative-risk-analysis-management-tool-cramm/103133 (дата звернення: 25.10.2026).

4. Alberts C., Dorofee A. Managing Information Security Risks: The OCTAVE Approach. Boston : Addison-Wesley, 2002. 471 p.

5. Caralli R. A., Stevens J. F., Young L. R., Wilson W. R. Introducing OCTAVE Allegro: Improving the Information Security Risk Assessment Process : CMU/SEI-2007-TR-012. Pittsburgh : Software Engineering Institute, 2007. 154 p. URL: https://courses.cs.ttu.ee/w/images/a/a3/OCTAVE.pdf (дата звернення: 25.10.2026).

6. Risk Management: Implementation principles and Inventories for Risk Management/Risk Assessment methods and tools. Heraklion : ENISA, 2006. URL: https://www.enisa.europa.eu/sites/default/files/publications/D1_Inventory_of_Methods_Risk_Management_Final.pdf (дата звернення: 25.10.2026).

7. Peltier T. R. Information Security Risk Analysis. 3rd ed. Boca Raton : CRC Press, 2010.

8. Кіберзагрози, вразливості та моделювання атак на підприємство : лекція 3 з дисципліни «Кібернетична безпека підприємства». Київ : КНУ імені Тараса Шевченка, 2026.